Vulnerability Assessment Report

KEERTHAN C S
FUTURE INTERNS - CYBER SECURITY

http://demo.testfire.net/



EXECUTIVE SUMMARY & METHODOLOGY

A passive vulnerability assessment was conducted on the Altoro Mutual test web application http://demo.testfire.net/ to identify security misconfigurations and potential exposure points. The assessment was performed using the OWASP ZAP (Zed Attack Proxy) security tool to monitor web traffic and passively detect missing security headers, missing tokens, and information leaks. The following report outlines the identified vulnerabilities, their potential business impacts, and actionable remediation steps to improve the application's overall security posture.

Vulnerability 1: **Absence of Anti-CSRF Tokens**
Risk Level: Medium
Business Impact: This website is missing a security token on its forms. Because of this, an attacker could trick a logged-in user into clicking a bad link, which could force the user's account to transfer money or change a password without them knowing.
Remediation: Developers must use a vetted anti-CSRF package or framework (like OWASP CSRFGuard) to add unique, unpredictable tokens to all HTML forms.

Vulnerability 2: Content Security Policy (CSP) Header Not Set
Risk Level: Medium
Business Impact: This website is missing a rulebook (policy) that tells the browser which scripts are safe to run. Without this, a hacker could inject malicious code into the website, potentially stealing data from other users who visit the site.
Remediation: The server administrators need to configure a proper Content-Security-Policy HTTP header that strictly defines which sources of content are trusted and allowed to load.

Vulnerability 3: Missing Anti-clickjacking Header
Risk Level: Medium
Business Impact: The response does not protect against "ClickJacking" attacks. This means a hacker could load this banking site inside an invisible frame on their own malicious website to trick users into clicking buttons they did not intend to click.
Remediation: The server must be configured to use the X-Frame-Options HTTP header (set to DENY or SAMEORIGIN) or the Content-Security-Policy frame-ancestors directive.

Vulnerability 4: Server Leaks Version Information
Risk Level: Low
Business Impact: The web server is leaking its specific software version (Apache-Coyote/1.1) in the response header. Hackers can use this specific version number to easily search for known weaknesses to plan a targeted attack.
Remediation: Ensure the web server or load balancer is configured to suppress the "Server" header or only provide generic details.